MunichTech GmbH

INFORMATION SECURITY MANAGEMENT SYSTEM

Corrective Action Plan (CAP) Closure Memo

Document Reference	MT-ISMS-CAP-001
Version	1.1
Effective Date	26 October 2026
Prepared By	Head of Engineering (Interim CISO)
Verified By	Big 4 GRC Advisory (Internal Auditor)
Approved By	CEO / Managing Director, MunichTech GmbH
Confidentiality Level	**INTERNAL**

Table of Contents

1. Purpose
2. Closure of Minor Non-Conformity (MiNC)
3. Closure of Opportunity for Improvement (OFI)
4. Attestation of Closure

1. Purpose

This memorandum formally documents the remediation and closure of findings identified during the FY2026 Q2 Pre-Certification Internal Audit (Ref: MT-ISMS-AUD-001). This document satisfies the requirements of ISO 27001:2022 Clause 10.2 (Nonconformity and corrective action) by providing evidence that non-conformities have been addressed, and records the resulting improvement under Clause 10.1 (Continual improvement). This memorandum was reissued as version 1.1 on 26 October 2026 to correct the clause reference and to record the internal auditor as Big 4 GRC Advisory; no closure decision, finding, date or signature is changed.

2. Closure of Minor Non-Conformity (MiNC)

Audit Reference: AUD-02

ISO Control / Clause: Clause 6.1.3 (Risk Treatment)

Original Finding: Risk RR-013 (Key Person Dependency) has an inherent score of 12 (High) and a residual score of 6, and is marked as Accepted in the Risk Register. However, the mandatory CEO signature column acknowledging this risk acceptance was left blank.

Root Cause Analysis: Administrative oversight. The Risk Register was updated via an async Jira workflow, but the physical/digital signature protocol for high-tier risks was not integrated into the automated approval gate.

Corrective Action Taken:

The CISO presented the Risk Register to the CEO during the Management Review meeting on 20 April 2026.

The CEO formally signed and approved the acceptance of Risk RR-013.

The ISMS standard operating procedure for risk updates was modified: Any risk with an inherent score of 12 or higher now triggers a mandatory DocuSign workflow to the CEO to prevent future administrative lapses.

Evidence of Remediation: Updated and signed MT-ISMS-RR-001 (Version 1.1).

Auditor Verification: The Big 4 GRC Advisory internal auditor has reviewed the updated Risk Register and verified the CEO signature.

Status: CLOSED

3. Closure of Opportunity for Improvement (OFI)

Audit Reference: AUD-06

ISO Control / Clause: A.8.10 (Information deletion)

Original Finding: S3 Lifecycle policies were correctly configured to permanently delete client telemetry after 24 months (DSGVO Art. 17). However, an OFI was issued recommending the implementation of automated unit tests to verify these Terraform rules are not accidentally removed during future CI/CD pipeline runs.

Action Taken: The DevOps team integrated the open-source tool Terratest into the GitHub Actions CI/CD pipeline.

Implementation Detail: A specific unit test was written that evaluates the aws_s3_bucket_lifecycle_configuration resource block before any deployment. If a developer accidentally issues a pull request that removes the 24-month deletion rule, the GitHub Action automatically fails the build, preventing the non-compliant code from reaching the eu-central-1 production environment.

Evidence of Remediation: GitHub pull request #442 (merged). Screenshot of successful Terratest execution logs demonstrating the lifecycle policy verification.

Auditor Verification: The Big 4 GRC Advisory internal auditor observed a live demonstration of the CI/CD pipeline blocking a mock deployment that lacked the deletion policy.

Status: CLOSED

4. Attestation of Closure

The corrective actions detailed above have been successfully implemented, verified, and embedded into standard operations. The ISMS is now free of open non-conformities from the Q2 audit cycle.

Head of Engineering (Interim CISO) (Remediation Owner):

Signature: _____ Date: 9 July 2026

Big 4 GRC Advisory — Internal Auditor (Verification):

Signature: _____ Date: 10 July 2026